

Turma: 6NACCOMP – Entrega 1

Disciplina: Redes de Computadores e Cibersegurança

Grupo: Score Smash

Integrantes:

Flavia da Costa R Faria 20021548

Guilherme Muniz Gomes 24026572

Lucas Moreira de Godoy 24026298

Maria Eduarda Cabral Foloni 24026502

Introdução

O projeto desenvolvido pelo grupo consiste em um jogo físico gamificado de precisão, no qual o jogador deve lançar uma bolinha em uma área formada por uma malha de lasers e sensores LDR. A interrupção dos feixes permite identificar a posição atingida nos eixos X e Y, possibilitando determinar a pontuação correspondente a cada jogada.

O sistema utiliza Arduinos para realizar a leitura dos sensores, processar a posição detectada e controlar um painel de LEDs que fornece retorno visual ao jogador. Além disso, os dados gerados durante as partidas serão enviados para um sistema digital, permitindo o registro e a visualização de informações como pontuação, acertos, posições atingidas, histórico de jogadas e ranking em um dashboard.

Este relatório tem como objetivo analisar os aspectos relacionados à segurança e à comunicação do sistema, identificando possíveis vulnerabilidades no fluxo de dados, no código e na integração entre os dispositivos, bem como propor medidas de mitigação e boas práticas de cibersegurança.

Arquitetura do Sistema

O sistema é composto por uma estrutura física de detecção, uma camada de processamento embarcado e uma camada digital responsável pelo armazenamento e visualização dos dados gerados durante as partidas.

Lasers + LDRs -> Arduino -> Processamento da posição -> Matriz de LEDs -> Comunicação com o sistema digital -> API / Backend -> Banco de dados -> Dashboard

Na estrutura física, são utilizados **lasers e sensores LDR** distribuídos nos eixos X e Y. Quando a bolinha atravessa a área de jogo, ocorre a interrupção de determinados feixes de laser, permitindo identificar a posição correspondente ao acerto.

Os **Arduinos** são responsáveis por receber os sinais dos sensores, processar a posição detectada e controlar os atuadores do sistema. O circuito utiliza o **74HC4067** para auxiliar na leitura dos sensores e os **74HC595** para possibilitar o controle da matriz de **64 LEDs**, organizada em 8x8 posições.

Após o processamento da jogada, os dados gerados, como coordenada atingida e pontuação, deverão ser enviados para uma camada digital composta por **API/backend, banco de dados e dashboard**. Essa camada será responsável por registrar e apresentar informações como pontuação, quantidade de acertos, posições atingidas, histórico das jogadas e ranking dos participantes.

Arquitetura de Rede

A arquitetura de rede do sistema será responsável pela comunicação entre o protótipo físico e a camada digital da aplicação. Após a identificação da posição atingida pela bolinha, os dados processados pelos Arduinos deverão ser enviados para um módulo com conectividade de rede, permitindo a comunicação com o backend do sistema.

Para essa comunicação, será utilizada uma conexão por **Wi-Fi**, por meio de um módulo ou microcontrolador com suporte à rede, como o **ESP32**. Esse dispositivo será responsável por transmitir os dados da jogada para uma **API**, que fará o recebimento, validação e encaminhamento das informações para o banco de dados.

A partir do banco de dados, as informações poderão ser consultadas pelo dashboard, permitindo a visualização de dados como pontuação, coordenadas atingidas, quantidade de acertos, histórico das partidas e ranking dos jogadores.

Sensores e LDRs-> Arduino -> ESP32 / módulo Wi-Fi -> Matriz de LEDs -> Rede Wi-Fi -> API / Backend -> Banco de dados -> Dashboard

A comunicação pela rede deverá considerar mecanismos de segurança, como autenticação dos dispositivos, validação dos dados recebidos e uso de comunicação protegida entre o dispositivo e a API.

Análise de Vulnerabilidades

Com base na arquitetura planejada para o sistema, foram identificados alguns pontos que poderão representar riscos de segurança durante o desenvolvimento e a integração entre o protótipo físico e a camada digital.

As principais vulnerabilidades potenciais consideradas são:

- **Comunicação sem criptografia**
Caso os dados sejam enviados pela rede utilizando HTTP sem proteção, informações da partida poderão ser interceptadas ou alteradas durante a transmissão.
- **Ausência de autenticação do dispositivo**
Se o backend aceitar dados de qualquer dispositivo sem validar sua identidade, um equipamento não autorizado poderá enviar informações falsas para o sistema.
- **Dados de jogada sem validação**
Coordenadas, pontuações ou identificadores enviados pelo dispositivo podem ser manipulados caso a API não verifique se os valores recebidos são válidos.
- **Credenciais ou tokens expostos no código**
Chaves de acesso, senhas ou tokens armazenados diretamente no código-fonte podem ser visualizados por terceiros, principalmente caso o repositório seja público.
- **Controle de acesso inadequado**
Usuários sem permissão podem tentar acessar funções administrativas, alterar partidas, visualizar dados restritos ou modificar registros.
- **Falta de proteção contra requisições maliciosas**
A API pode receber entradas inválidas ou maliciosas caso não exista validação adequada dos dados enviados.
- **Ausência de registros de segurança**
Sem logs de autenticação, falhas e operações críticas, torna-se mais difícil identificar comportamentos suspeitos ou investigar incidentes.

Esses riscos estão alinhados aos requisitos de segurança definidos no projeto, que incluem autenticação segura, autorização por perfil, proteção de credenciais, validação de entradas, comunicação cifrada, menor privilégio e segurança dos dispositivos IOT.

Classificação dos Riscos

Para classificar os riscos identificados, foram considerados dois fatores principais: **probabilidade de ocorrência** e **impacto causado ao sistema**.

Vulnerabilidade	Probabilidade	Impacto	Nível de risco
Comunicação sem criptografia	Média	Alto	Alto
Ausência de autenticação do dispositivo	Média	Alto	Alto
Dados de jogada sem validação	Alta	Médio	Alto
Credenciais ou tokens expostos no código	Média	Alto	Alto
Controle de acesso inadequado	Média	Alto	Alto
Requisições maliciosas sem validação	Média	Médio	Médio
Ausência de logs de segurança	Média	Médio	Médio

Os riscos classificados como altos deverão receber maior prioridade durante o desenvolvimento do sistema, principalmente aqueles relacionados à autenticação, proteção da comunicação e validação dos dados recebidos. Já os riscos classificados como médios também deverão ser tratados, porém podem ser implementados em etapas posteriores do desenvolvimento, desde que não comprometam a segurança do sistema.

Testes de Segurança

Os testes de segurança serão realizados conforme os componentes do sistema forem implementados. O objetivo será verificar se as vulnerabilidades identificadas na etapa de análise foram devidamente tratadas e se a comunicação entre o protótipo físico e a aplicação digital ocorre de forma segura.

Os principais testes planejados são:

- **Teste de comunicação segura**
Verificar se os dados enviados entre o dispositivo e a API utilizam conexão protegida, preferencialmente por HTTPS, evitando a transmissão de informações em texto aberto.
- **Teste de autenticação do dispositivo**
Verificar se apenas dispositivos autorizados conseguem enviar dados para a API.
- **Teste de validação dos dados**
Enviar valores inválidos ou fora do padrão esperado, como coordenadas inexistentes ou pontuações alteradas, para verificar se a API rejeita esses dados.
- **Teste de controle de acesso**
Verificar se usuários sem permissão conseguem acessar funções administrativas ou modificar dados que não deveriam estar disponíveis.
- **Verificação de credenciais no código**
Analisar o código-fonte para garantir que senhas, tokens e chaves de acesso não estejam armazenados diretamente nos arquivos do projeto.
- **Teste de entradas maliciosas**
Realizar tentativas de envio de dados inesperados ou malformados para verificar se o sistema possui validação adequada.
- **Verificação de logs**
Confirmar se eventos relevantes, como falhas de autenticação, erros de comunicação e tentativas de acesso indevido, são registrados corretamente.

Medidas de Segurança / Mitigações

Para reduzir os riscos identificados, serão adotadas medidas de segurança ao longo do desenvolvimento do sistema. As principais ações previstas são:

- **Utilização de comunicação criptografada**
A comunicação entre o dispositivo e a API deverá utilizar protocolos seguros, como HTTPS, reduzindo o risco de interceptação ou alteração dos dados transmitidos.
- **Autenticação dos dispositivos**
Os dispositivos responsáveis pelo envio das informações deverão ser identificados e autenticados antes de transmitir dados ao backend.

- **Validação dos dados recebidos**
A API deverá verificar se os valores recebidos estão dentro dos padrões esperados, como coordenadas válidas, pontuações permitidas e identificadores existentes.
- **Proteção de credenciais e tokens**
Senhas, chaves e tokens não deverão ser armazenados diretamente no código-fonte. Esses dados deverão ser mantidos em variáveis de ambiente ou mecanismos apropriados de gerenciamento de segredos.
- **Controle de acesso por perfil**
As funcionalidades do sistema deverão respeitar os diferentes níveis de acesso, impedindo que usuários comuns executem ações administrativas.
- **Tratamento de entradas inválidas ou maliciosas**
As entradas recebidas pelo sistema deverão passar por validação antes de serem processadas, reduzindo riscos relacionados a dados malformados ou requisições indevidas.
- **Registro de eventos e falhas**
O sistema deverá armazenar logs relacionados a autenticação, erros de comunicação, acessos e operações críticas, permitindo análise posterior em caso de falha ou tentativa de ataque.

Evidências

No momento desta entrega, o projeto ainda se encontra em fase inicial de desenvolvimento e **não possui implementação funcional de software, API, comunicação em rede ou integração com o dashboard**. Por esse motivo, ainda não existem evidências práticas de testes de segurança, como capturas de tela, logs, resultados de ferramentas de análise ou comparações entre código vulnerável e código corrigido.

As evidências serão adicionadas nas próximas etapas do projeto, conforme os componentes forem implementados e os testes de segurança forem executados. Futuramente, esta seção deverá incluir registros de testes de autenticação, validação de dados, controle de acesso, comunicação segura, proteção de credenciais e análise de vulnerabilidades.

Para esta etapa, a análise apresentada no relatório possui caráter **preventivo e de planejamento**, com foco na identificação antecipada dos principais riscos de segurança que deverão ser considerados durante o desenvolvimento.

